ConPro PMIS Empowered with RAG AI - Platform Design and Implementation Review

ConPro PMIS Empowered with RAG AI

Platform Design and Implementation Review

1. Executive decisions and success criteria
2. Evidence baseline and immediate readiness blockers
3. Target architecture and trust boundaries
4. System-wide PMIS coverage and authority
5. Data classification, inventory and retention
6. Storage integrity and consistency
7. Security and authoritative authorization
8. AI-agent intrusion defense and platform protection
9. Ingestion, file safety and provenance
10. AI correctness, abuse and business safety
11. Availability and graceful degradation
12. Disaster recovery and backup design
13. Performance and capacity engineering
14. Scalability and deployment stages
15. Geography, latency and consistency
16. Observability, audit, operations and cost
17. Critical reference implementation patterns
18. Implementation batches, ownership and rollback
19. Acceptance tests and assurance evidence
20. Operator runbooks and incident response
21. Assumptions, limitations and future recommendations
22. Coverage register and approval gate
23. Glossary
24. References

ConPro PMIS Empowered with RAG AI

Platform Design and Implementation Review

Date: 2026-10-16
Version: 1.1
Status: **REVIEW COPY - NOT APPROVED FOR IMPLEMENTATION**

Revision 1.1 adds a dedicated AI-agent/automated-intrusion defense design, credentialed-abuse controls, isolated agent workspaces, implementation batches and adversarial acceptance gates. These are proposals, not deployed protections.

Scope: documentation only. This package is stored in the RAG repository. ConPro is inspected read-only; no ConPro file, application, database, UI, configuration, deployment or running service is changed. Neither writing this document nor accepting its recommendations authorizes integration work.

Security assurance boundary: no document can guarantee that nothing will ever expose a PMIS. This design identifies trust boundaries, controls, known readiness gaps, failure behavior, verification evidence and accountable owners. Production approval requires implementation, independent testing, deployment inspection, recovery drills and acceptance of remaining risks. Unverified is not equivalent to secure. All source and external references appear at the end.

1. Executive decisions and success criteria

Enhance the **whole ConPro PMIS**, not only Scratch-pad. Preserve authoritative business records, existing permissions, workflows and deterministic calculations. Treat AI as an optional, read-only assistance capability whose failure does not disable normal project administration.

The central design decisions are:

1. ConPro remains the authority for identity, source visibility, field/export rights, record lifecycle and financial/schedule facts.
2. Keep authoritative business data and original files separate from rebuildable RAG text, vectors, lexical indexes, generated descriptions and answer history.
3. Authorize before retrieval, not after the model has seen the information. Recheck policy and source generations at dispatch, return and later history reads.
4. Contain AI outages, parsing failures, expensive searches and provider bills behind separate resource budgets. Never relax permissions to improve availability.
5. Establish durable storage and tested recovery before adding replicas or users. Replication is not backup; a successful backup job is not a successful restore.
6. Scale measured workloads, not an assumed number of registered users. Keep current RAG process limits until shared state has been externalized.
7. Make every implementation batch small, reversible and evidence-gated. Existing UI changes require separate approval; a backend policy extraction does not require a UI redesign.
8. Treat external AI agents, browsers, scripts and internal tools as untrusted clients until their identity and requested action are authorized. Defend against stolen credentials and misuse of valid functionality, not only bots that identify themselves as bots.

Success means authorized users can obtain timely, attributable information while the platform rejects unauthorized disclosure, preserves business correctness and recovers predictably. AI fluency, an attractive demo and high request throughput are not substitutes for those properties.

2. Evidence baseline and immediate readiness blockers

2.1 What exists versus what is proposed

Area	Current source evidence	This document proposes
ConPro	Django/DRF backend, React UI, PostgreSQL, filesystem document storage, project/record policy and protected downloads.	Hardened production storage/operations plus a separately approved backend RAG adapter.
RAG access	Personal keys, explicit tenant/project grants, scoped ingestion/jobs, internal service token.	Authoritative ConPro subject/source policy and separate integration identities.
Retrieval	FAISS, pgvector and mirrored storage; text-only reranking; process-local locks/revisions.	Durable source generations, exact authorized evidence, optional independent lexical retrieval and validated fusion.
Reliability	Bounded question admission; short retrieval locks; single-process ingestion queue.	Durable jobs, fair quotas, distributed admission and tested failover before horizontal RAG scaling.
Saved answers	Optional owner-only private store, up to 30 days, local FAISS only; conservative observed-policy/index invalidation.	ConPro source-version-aware retention and durable revocation propagation.
Images	Separate local OCR and opt-in OpenAI descriptions; generated descriptions labelled unverified.	Classification-approved processing, stronger isolation and representative accuracy evaluation before PMIS use.
Integration	Earlier review plans and reference fragments.	Implementation gates; no connector is installed by this paper.
Automated/agent intrusion	General access, network, quota and file-safety controls are documented; agent-specific deployment enforcement was not verified.	Registered automation, bounded delegated authority, anti-harvesting controls, credential lifecycle, isolated tool workspaces and durable containment.

RAG evidence includes its current working-tree changes, not only the last commit. Historical test results of 170 Python passes/two skipped PostgreSQL tests, 19 frontend passes and a successful build concern standalone RAG changes. They are **not** proof of ConPro integration, enterprise capacity or production recovery. A synthetic live image test was not a confidential-PMIS validation.

2.2 Concrete configuration concerns to resolve first

ID	Observed condition	Required decision and evidence
B01	ConPro Compose selects PostgreSQL 18 while its named data volume targets the older data-directory location. The official PostgreSQL 18 image changed its default `PGDATA` and volume root.	Inspect the actual deployed image, data directory and mounts in an approved environment. Back up and restore first; migrate deliberately. A container recreation must preserve records. Do not blindly change a mount on an existing cluster.
B02	ConPro uses filesystem media; the reviewed backend Dockerfile/Compose do not declare persistent uploaded-file storage. The database volume alone does not protect those files.	Provision protected persistent media/object storage and an application-consistent backup/recovery contract. Prove upload, container replacement and exact-version download in staging.
B03	Development database configuration includes convenience credentials; the image initialization user may be a superuser.	Production must use managed secrets and distinct non-superuser runtime roles. Inspect actual privileges rather than assume an example Compose file is hardened.
B04	ConPro starts migrations/reporting installation from its backend entrypoint.	Before multiple replicas, use one controlled migration job with compatibility/rollback gates. Do not run concurrent schema migrations from every replica.
B05	ConPro's scheduler is a single looping process; duplicate schedulers are not demonstrated safe for every task.	Introduce a leader lease and durable, idempotent run identities before scheduler replication.
B06	RAG jobs, admission, caches, metrics and some history remain process-local; pgvector has a local connection/lock wrapper.	Keep one RAG API worker until every relevant shared-state dependency is addressed. A persistent vector database alone does not make the API stateless.
B07	Internal RAG retrieval authenticates a service, not individual ConPro record permissions.	No public/browser access; enforce authoritative source scopes in the integration path and prevent legacy routes from reaching ConPro-derived data.
B08	No deployed HA, backup restore, key recovery, residency, capacity or end-to-end integration evidence was established in this review.	Treat each as an explicit release gate with named owners, not as an existing capability.

B01/B02 are storage-readiness concerns identified from configuration, not claims that a production database or a user's files have already been lost. No live ConPro cluster or stored document was inspected. No remediation is executed here.

2.3 Bounded security review result

A separate read-only review confirmed important trust-boundary and deployment conditions, but **did not confirm a current exploitable vulnerability within its bounded scope**. It did not certify production safety. The missing ConPro connector is an integration gap, not evidence that one is already exposed.

Public document-sharing endpoints are an intentional separate authorization mechanism, not automatically an authentication bypass. Future AI citations must not mint or reuse public sharing links implicitly. Forwarded-IP/request-ID/source headers are audit hints unless a trusted ingress strips and normalizes them.

The version 1.1 agent-defense review assessed the design document, not deployed ConPro controls. It confirmed no current exploitable vulnerability within that scope; its proposed control refinements are not reports of a successful intrusion.

3. Target architecture and trust boundaries

3.1 Logical topology

```
Authorized users, existing ConPro UI
    |
    v
TLS ingress / identity / request and upload limits
    |
    v
Existing ConPro API and approved AI adapter
    |-- authoritative policy and deterministic facts
    |-- business DB + durable mutation/outbox transaction
    |-- protected immutable file/version storage
    |-- minimal durable audit evidence
    |
    +--> private authenticated RAG integration boundary
             |-- opaque, short-lived, subject-bound policy context
             |-- bounded authorized retrieval
             |-- separate RAG-derived DB/index storage
             |-- dispatch policy check --> approved model egress
             |-- evidence/claim validation + return policy check
    |
    +<-- final ConPro permission/freshness check and protected citations

Asynchronous indexing:
durable outbox --> leased worker --> malware/format/parser isolation
              --> staged extraction + embeddings + lexical index
              --> fenced atomic publication + receipt

Independent operations plane:
metrics + restricted audit + secret management + backup/recovery + incident response
```

Use logical separation first. Do not introduce Kubernetes, a general agent framework, multiple brokers or active-active regions merely to make the diagram look scalable. A controlled pilot can use a transactional database outbox and one worker. HA requirements may later justify additional infrastructure.

3.2 Allowed communication

Caller	Destination	Permitted purpose	Default
Browser	ConPro public API	Existing authenticated business and approved AI operations.	TLS, explicit identity/session policy, bounded requests.
Browser	Private RAG integration/internal search, DB, blob bucket	None.	Deny.
ConPro adapter	Private integration API	Approved ask/scope/index operations through separate service roles.	Verified TLS; mTLS where available; application authentication still required.

Caller	Destination	Permitted purpose	Default
RAG	ConPro policy/export/facts callbacks	Fixed-origin, narrow server-owned operations only.	Deny arbitrary URLs, functions and SQL.
Worker	Quarantine/storage/index	Source manifests and bounded derived-data publication.	No blanket business-table or provider access.
Inference component	Approved provider endpoint	Approved classified context/image only.	Egress allowlist, budget and processor policy.
Operators	Administration plane	Time-bound maintenance through approved access paths.	MFA, least privilege, audit and break-glass review.

mTLS proves service identity and protects transport; it does not authorize a human to read a project or document. A network perimeter is not a replacement for application authorization. An internal token is a privileged credential.

3.3 Preserve existing paths

Keep existing ConPro business APIs and the standalone RAG API operational under their own policies. The proposed connector owns a private namespace and separate corpus roles. Existing personal-key `/ask` or internal `/search` must not provide an alternative path into ConPro-derived data without ConPro authorization.

Prevent bypass at the data-access boundary, not only with a URL-prefix check. Use distinct storage roles/schema boundaries and server-owned corpus ownership. No browser field may select an integration namespace or forge an authorization manifest. A missing integration policy context denies ConPro-corpus access.

4. System-wide PMIS coverage and authority

Domain	AI assistance after approval	What stays authoritative
Projects/contracts	Explain obligations, milestones, risks and permitted project context.	Contract records, project/company rights and approved baseline definitions.
Document control	Find requirements, summarize current eligible versions, later compare explicit revisions.	Exact version, approval/effective status, confidentiality and authenticated source action.
RFIs/submittals	Explain permitted history and prepare human-reviewed drafts.	Workflow state, authorized responses, issuance and approval.
Changes/commercial	Trace supporting evidence and explain approved changes.	Entitlement, valuation, commercial confidentiality and certification.
Payments/cost/cash flow	Explain dated deterministic metrics and permitted variances.	Decimal/currency/period definitions, ledger calculations, approval and payment.
Schedule	Explain approved activity facts and documented delay causes.	Schedule calculation, calendars, dependencies, critical path and baseline changes.
Daily reports/quality	Summarize authorized observations, inspections and findings.	Parent-record visibility, draft/locked status and existing QC calculations.

Domain	AI assistance after approval	What stays authoritative
Incidents/NCRs	Later limited summaries of approved non-restricted fields.	Duty, row/field rights; medical/HR/privileged sections excluded by default.
Reporting/portfolio	Explain approved report receipts and authorized cross-project aggregates.	Existing report calculations, scope and numeric/reference validation.
Attachments/custom fields	Approved bounded projections with provenance.	Parent permission and field-by-field allowlists, not whole-object serialization.
Accounts/audit/ethics	Approved policy guidance, not unrestricted identity/log search.	Authentication, role policy, ethics, audit access and segregation of duties.
Scratch-pad	Optional private note/draft assistance.	Note ownership and existing workflow; not the integration's only entry point.

Use three distinct evidence contracts: versioned **documents**, safe versioned **record projections**, and **live deterministic facts**. An indexed number is not a current balance. A generated explanation cannot approve a payment, certify work, close an incident or modify a schedule.

5. Data classification, inventory and retention

5.1 Classification travels with derived data

Adopt owner-approved classes such as public, internal, confidential and restricted, mapped to real ConPro policy. These labels are a proposed vocabulary, not permission to replace existing confidentiality rules.

Generated summaries, embeddings, lexical tokens, citations and image descriptions inherit the source's restrictions; transformation is not declassification. Combined answers require the intersection of permissions for every dependency. Identifiers and source-existence information can themselves be sensitive.

Data asset	Storage authority and protection	Lifecycle requirement
Business rows/workflow state	ConPro transactional database; constrained runtime roles.	Approved legal/contract schedule; immutable approval/audit evidence where required.
Original files and versions	Protected persistent media/object store with version/digest mapping.	Lifecycle, retention/hold, integrity and authenticated exact-version downloads.
Authorization/session/grant state	ConPro identity/policy authority.	Revocation and account lifecycle; never copied into a searchable corpus.
RAG source registry/manifests	Separate derived store with signed/protected provenance.	Sequence/tombstone history survives source deletion and stale replay.
Extracted text/OCR	Derived encrypted storage, if retained at all.	Source-bound retention, delete/rebuild, parser/profile identity.
Image descriptions	AI-derived unverified content with model/provenance.	Same or stricter source restrictions; not verified OCR/drawing understanding.
Embeddings/lexical indexes	Private RAG store, least-privilege roles.	Source-version/profile-bound; no public vector search or dump.
Query context and provider input	Minimized in-memory payload where possible.	No generic raw-prompt logs; approved external processing and deletion terms.

Data asset	Storage authority and protection	Lifecycle requirement
Saved question/answer bodies	Separate owner/source-bound store, not generic audit.	Explicit opt-in; maximum/default 30 days unless a separately approved policy changes the product.
Feedback/corrections/evaluation	Restricted owner-approved dataset.	No alternate answer archive; source-aware access, redaction and consent rules.
Audit/security evidence	Restricted, integrity-protected append-oriented store.	Owner/legal-approved schedule, no raw confidential payloads by default.
Jobs/outbox/dead letters	Durable operational metadata, minimum payload.	Bounded history, expiry, redaction and parent/owner access checks.
Exports/previews/search snippets	Authenticated delivery, no public/private cache confusion.	Expiry, source rechecks, download auditing; approved offline-use limits.
Backups/replicas/WAL/snapshots	Separate protected recovery plane.	Approved expiry, key access, immutable copies and deletion/revocation replay.
Secrets/private keys	Managed secret/key service or approved private mounts.	Rotation, revocation, recovery and access audit; never in code or indexed text.

5.2 Retention is a governed schedule

Do not apply the 30-day AI-answer rule to statutory business records, original project documents or financial audit evidence. Approve a schedule per asset, jurisdiction, contract, classification and storage location before production. Record owner, purpose, trigger, duration, legal hold, deletion mechanism, backup lag and verification evidence. Unresolved mandatory retention blocks release.

A legal hold preserves only approved material under restricted access; it does not restore ordinary user visibility to revoked answers. Segregate hold copies from interactive history and require explicit custodial authority.

5.3 Revocation and later reads

The safe default is **not to reveal previously protected content on a later read**. For ConPro-integrated history, recheck the owner/account, project, all supporting source versions, field/export rules and relevant processing restrictions. Any unverifiable dependency withholds the entire question/answer, not a model-generated partial redaction. Known revocation irreversibly scrubs its interactive payload and triggers dependent-data invalidation.

Durable monotonic revocation events must work even if nobody reads an answer during a temporary withdrawal. Regranting access must not resurrect scrubbed history. The standalone FAISS retention fingerprint is not a distributed revocation ledger and cannot detect changes reverted before observation.

Expired content must be unavailable at the deadline even when physical cleanup is asynchronous. Publish a measured deletion SLA and backup/provider exceptions. Already delivered text, screenshots, user copies and provider disclosures cannot be recalled by deleting a database row.

6. Storage integrity and consistency

6.1 Authoritative relational storage

Use supported, deliberately pinned PostgreSQL releases with a tested upgrade path, WAL/PITR, durable storage and monitored disk headroom. Database startup health is not proof that data is on the intended persistent mount.

Use separate identities for migrations/ownership, ConPro runtime, RAG query, RAG ingestion, reporting and backup. Runtime roles must not be superusers, table owners or BYPASSRLS roles. RAG never receives write access to ConPro's business database. Separate schemas alone are not physical fault isolation.

Preserve business transactions, foreign keys, uniqueness, optimistic concurrency or version checks, monetary precision and idempotency at existing mutation boundaries. Do not use an eventual vector index as the ledger or workflow state. Bound connections, statements, lock waits and long transactions; alert on WAL, replication lag, vacuum debt, transaction age and exhausted storage.

6.2 Original-file storage

Persist an immutable object/version and verify its checksum before committing the database pointer. A database transaction and object-store upload are not one atomic resource: use explicit pending/finalized state, idempotency and orphan reconciliation. Never publish a pointer to an unverified/unavailable blob.

Protect storage from public listing/reads. Source downloads remain authenticated and version-specific. If signed delivery URLs are later approved, bind method, object/version, audience and short expiry; do not expose reusable public links. For strict revocation, use an authenticated download gateway because an already issued offline URL cannot always be recalled instantly.

Use versioning/retention locks where appropriate, with restricted deletion, separate recovery credentials, malware quarantine and lifecycle policies. Versioning preserves old sensitive copies too; it is not automatic compliance. Enforce quotas before accepting very large uploads, and stream instead of buffering whole project files into application memory.

6.3 Source and index identity

The integration registry needs at least:

```
deployment namespace + authorized project
source kind + record ID + immutable source/version ID
content digest + safe-projection version + extraction/index profile
monotonic desired sequence + publication generation + eligibility/tombstone state
genuine chunk IDs + verified locators + processing provenance
```

Hashes establish consistency with a protected approved baseline, not content safety. Protect manifest updates/signing keys independently from ordinary source writers; an attacker able to replace both blob and digest defeats a bare checksum. Model/profile upgrades create new generations; never silently mix incompatible embedding dimensions, lexical profiles or citation mappings.

6.4 Publication and deletion

Stage parsing and index changes outside long business transactions. Publish the complete eligible generation and readiness receipt atomically in the derived database. Both dense and lexical branches must use the same authorized version set and retrieval snapshot. A new draft revision must not accidentally leave a withdrawn old revision available as the "current" answer.

Source withdrawal first denies eligibility in authoritative policy; then remove derived text, vectors, lexical data, previews, context caches, summaries, retained answers and job-result payloads under the approved deletion schedule. Tombstones/source sequences survive document/folder cascades and defeat stale retries. Reconciliation repairs storage differences but never grants access.

6.5 Portability and provider exit

Retain original files, stable version identifiers and documented export schemas independently of the model/vector vendor. An approved export includes permitted business records, file/version manifests, checksums, provenance and audit mappings; it does not indiscriminately include secrets, restricted fields or revoked answers. Authorize and audit bulk exports separately, encrypt delivery, expire access and protect spreadsheet exports from formula injection.

Exercise import/reconstruction into a clean approved environment, not only export creation. Preserve source identities and current access restrictions during moves. Define vendor termination, credential revocation, certified deletion where contractually available, and backup/hold exceptions. Changing embedding models normally requires reindexing; possession of a proprietary vector dump is not a complete exit strategy.

7. Security and authoritative authorization

7.1 Single policy authority, multiple enforcement points

A proposed shared ConPro visibility helper should extract existing behavior, not invent new access rules. The ordinary document endpoints and AI adapter use the same authoritative checks. Preserve active membership, role expiry, ethics, company, record, confidentiality, version and field-specific restrictions. Project access alone is insufficient; oversight/superuser status is not a blanket permission to disclose every restricted section to an AI provider.

Export/processor rights can be stricter than viewing. Bulk queryset filtering does not prove every object/field/export decision has been made. Prove equivalence against existing policy with allowed and denied cases before changing callers.

7.2 Query authorization sequence

1. Authenticate the real user in ConPro; validate account/session and API policy.
2. Resolve the requested project/operation server-side; deny ambiguous or forbidden cross-project access without revealing protected existence/counts.
3. Construct the exact eligible source-version set from authoritative policy. Apply safe field projections and classification/processor restrictions.
4. Issue a cryptographically random, opaque, short-lived query handle with hash-only storage, bound to subject/session, project, question digest, request, sources/generations, processor, model/profile and phase.
5. The private RAG boundary validates service identity and resolves the handle through a fixed callback; a handle is not a reusable general access token.
6. Retrieve only within the authorized source/version set before scoring, ranking, snippets, counts or context construction.
7. Release retrieval transactions; recheck live permissions and generations immediately before sending any context/image to an approved processor.
8. Validate the bounded structured answer and citation ledger. Recheck policy/ freshness before RAG returns and independently before ConPro releases it.
9. Record minimal durable audit evidence under the approved failure policy.

10. Later history/source reads repeat current authorization; initial access is not permanent permission.

Use the companion plan's proposed 90-second maximum handle life only as a review starting point. It is not a 90-second permission cache; callbacks still recompute authoritative eligibility. If policy cannot be verified, fail closed.

7.3 Database defense in depth

An exact allowlist join is required for both retrieval branches. Optional PostgreSQL row-level security can reinforce namespace/project isolation, but it does not reproduce ConPro's document/field policy by itself. Owners/superusers can bypass normal RLS; explicitly inspect runtime privilege inheritance.

Pooled database contexts must use transaction-local trusted settings and clear state on every lease. Never carry tenant context between users. SQL injection or a compromised service able to choose its own context is outside the protection of a simple context-based RLS policy; use parameterized queries, constrained roles, separate corpus boundaries and authoritative scope validation as well.

7.4 Authentication, session and transport controls

Use existing ConPro authentication and published policy; production SSO/MFA and privileged step-up require an explicit identity deployment decision. Define real revocation semantics for issued access tokens, refresh/session revocation, account disablement, service tokens and signing keys. Do not promise instantaneous JWT revocation without an enforcing mechanism.

Require verified TLS outside local development, trusted proxy handling, secure cookie/CSRF/CORS/origin policy as applicable, and no credentials in URLs or browser persistent storage. Strip client-supplied forwarding/identity headers at ingress. Define token audiences, service roles, rotation overlap and revocation; do not share one broad credential across query, ingestion and callbacks.

7.5 Existing web-application controls still apply

RAG does not replace normal PMIS application security. Verify object/field checks on every mutation, download and export; parameterized queries; server-side input validation; explicit writable-field allowlists; and safe output encoding. Render model text/Markdown through an approved sanitizer, never trusted HTML. Apply a reviewed Content Security Policy, framing restrictions and safe file download headers; serve untrusted active content from an isolated origin or force download according to policy.

Test CSRF protections where cookie authentication is used, session fixation/ rotation, secure cookie attributes, credential-stuffing controls and safe account recovery. Rate limits must not let an attacker permanently lock out another user. Sensitive state must not survive logout in shared-browser caches or service workers. These are required verification items, not findings that the reviewed ConPro currently lacks every control.

8. AI-agent intrusion defense and platform protection

8.1 Baseline workload, network and operator controls

Layer	Required production control
Public ingress	Explicit hosts/origins; TLS; trusted forwarding; body/header/connection limits; per-user/project rate limits and bot/abuse controls.

Layer	Required production control
Application routing	No public private-integration/internal-search/admin endpoints. Authenticate before expensive body parsing where supported.
Internal network	Default-deny connectivity; only documented caller/destination pairs; private DB/storage/metrics; separate operations plane.
Provider egress	Fixed approved endpoints, DNS/TLS validation and egress rules; classification/residency gates; no arbitrary callback or model-selected URL.
Runtime	Non-root, minimum filesystem writes/capabilities, restricted temp directories, resource limits and patched parsers.
Secrets/keys	Managed storage, least privilege, no build-context/CI-log leakage, audited rotation and tested encrypted-backup key recovery.
Dependencies/models	Locked/reviewed dependencies, SBOM and image/model provenance, vulnerability review and signature/digest policy; no arbitrary model code execution.
CI/CD	Protected review/release identities, separate environments, signed/provenanced artifacts, secret scanning and staged rollout.
Administration	MFA, time-bound access, dual control for sensitive exports/holds/key destruction; no shared administrator accounts.
Development/testing	Synthetic or explicitly approved redacted fixtures; never copy production backups or secrets into developer/test environments.

Public Google Docs, app-only SharePoint and arbitrary database ingestion are not substitutes for ConPro's protected exporter. Keep the integration source catalog narrow. SSRF defenses must validate redirects and resolved destinations, deny metadata/link-local/private targets where inappropriate, and complement application checks with network egress controls.

8.2 Threat model: protect actions and data, not an "AI" label

An AI agent does not automatically bypass sound authentication and authorization. It can accelerate reconnaissance, credential attacks, social engineering and misuse of otherwise valid APIs. Protect every relevant client/action regardless of whether the caller is a human, browser automation, script, agent or plugin.

Do not promise to identify all AI traffic. `User-Agent`, bot scores, IP addresses, CAPTCHA, `robots.txt`, hidden URLs, prompt instructions and CORS are not access authorization. CORS restricts participating browsers, not arbitrary HTTP clients. WAF/bot defenses supplement origin protection and application controls.

Threat	Main defense and required assurance
Anonymous tool probes or unattended credential attacks	Protected ingress, patched exposed components, strong identity, safe errors and bounded authentication traffic; deny private endpoints at network and application layers.
Stolen valid user/session credentials	Phishing-resistant privileged MFA, protected recovery, short-lived credentials, enforceable revocation and high-risk step-up; do not trust a familiar browser fingerprint alone.

Threat	Main defense and required assurance
Approved agent exceeding its task	Registered service/delegation identity, narrow action/project/source/field scope, expiry and current ConPro permission checks; no transferable user-password automation.
Individually authorized reads used for mass harvesting	Separate export/processing rights plus cumulative disclosure controls across equivalent APIs, identities and replicas, subject to approved policy.
Poisoned document/OCR or malicious model output	Untrusted-data boundaries, no model tools/writes, approved egress and safe rendering; no automatic URL/image fetch or model-chosen callback.
Privileged local coding agent, plugin or tool server	Separate execution identity/workspace, no production secrets or ambient host privileges, restricted mounts/network and reviewed tool capabilities.
Resource/cost exhaustion or compromised worker	Distributed resource/cost admission, bounded jobs, least-privilege service roles and independently operable containment.

Residual limits matter: a client holding valid credentials may imitate ordinary user requests; authorized people can photograph or copy information already shown. An agent running as an administrator can exceed application-level boundaries. No bot detector or document can eliminate these risks.

8.3 Authorized-client and delegated-agent policy

Recognize human sessions, machine services and delegated agents as distinct identity types. Keep ordinary approved human access under existing ConPro policy; an agent cannot become a privileged service merely by sending an `agent=true` field or naming a known product.

Approved automation requires a server-owned registry with an accountable owner, business purpose, approved client identity, permitted actions, project/source/ field scope, processing destination, expiry, quotas and revocation state. Disable unregistered service/delegated access by default. This does not prove that an automated client cannot use stolen ordinary browser credentials.

For delegated work, effective authority is the intersection of current user rights, the registered client's grant, the delegated task grant, source/export/ processor policy and active security restrictions. No wildcard project, administrator inheritance or permission inferred from the model's instructions. Record both the acting client and the delegating user; validate their binding through the identity authority, never a caller-supplied subject header.

Separate query, ingestion, policy-callback, scheduler and administration roles. Read-only assistance grants no business write, command execution, account/role change, approval, public sharing or bulk export. Future agent actions require a separate reviewed proposal with per-action authorization and human approval for consequential operations. Approval of this paper does not enable automation.

8.4 Ingress identity contract and prevention of alternate routes

Inventory every public/legacy API, document/share/download path, WebSocket/stream, job/status endpoint, admin surface and internal service before rollout. Explicitly allow approved caller/route/method combinations; unknown combinations deny. Prevent direct origin access using network policy and origin authentication, not DNS obscurity. Keep developer previews and debug interfaces out of production.

Use the existing identity provider/framework, not custom token cryptography. If OAuth/OIDC is adopted, validate trusted issuer, intended audience, permitted algorithm/key, expiry and the approved client/subject binding. Use appropriate browser flows such as authorization code with PKCE rather than placing service

secrets in a frontend. Evaluate sender-constrained credentials, such as mTLS-bound tokens or DPoP, for privileged automation using reviewed standards libraries. A certificate alone still does not authorize a user's documents.

At ingress, strip untrusted identity/forwarding headers; construct trusted identity only from the verified authentication path. Authenticate the proxy and configure the exact trusted proxy chain at the origin. TLS termination, path/method normalization and sender-proof validation must agree on the actual destination. A proof bound to one request must not be reusable on another.

Enforce the same authoritative restrictions at application/data boundaries so a legacy endpoint, alternative hostname, service token or direct backend address cannot bypass the integration policy. Public sharing remains a separate explicit business capability: no AI-generated public link, permission upgrade or implicit approval for third-party model processing.

8.5 Credential theft, session lifecycle and recovery

Require phishing-resistant MFA for privileged human identities and approved step-up for sensitive exports, grant changes and recovery operations. Account recovery must not become a weaker bypass. Protect service keys in managed storage with minimal lifetime/scope and reviewed rotation; do not give an agent a user's password, refresh token, administrator session or production cloud credential.

Define access-token/session lifetimes, refresh rotation/reuse detection where applicable, logout/account-disable semantics, and key/service/client revocation. Specify a measurable enforcement deadline and test it across replicas; do not claim immediate revocation from token expiry alone.

For protected AI work, required live checks must consult current revocation/ containment authority at issuance, dispatch, publication, response release and later history reads. Jobs and outstanding query handles are included. A check started after an authoritative deny is committed must deny; already dispatched or delivered information cannot be recalled. If authority is unavailable, no new protected AI dispatch/release is allowed.

8.6 Cumulative extraction and abuse of legitimate access

Object-level access checks are necessary but do not govern unlimited harvesting. Approve bulk export, third-party AI processing and sensitive aggregation as separate capabilities. Apply classification-aware rolling limits to released bytes, distinct sources, downloads/exports, queries and expensive operations. Set actual thresholds from approved user workflows; no arbitrary production limits are established by this design.

Share counters/admission across equivalent list, search, download, preview, citation, export, history and AI paths. Aggregate by trusted subject/client, project and appropriate organization-wide ceilings, not IP alone. An agent must not evade its allowance by using several replicas, routes or fresh request IDs. For concurrency, reserve allowances atomically before disclosure and settle conservatively afterward. Denied requests reveal no protected source existence.

Use reviewed anomaly signals for slow extraction, unusual access patterns, repeated denials and coordinated identities. Thresholds and responses need privacy review, audit, accessible user messages and an appeal/escalation path. DLP/watermarking on managed devices can be additional controls, not a guarantee against screenshots, collusion or data copied outside managed infrastructure. Any intentional restriction on existing human workflows needs explicit approval and regression tests; it must not silently redefine ordinary visibility.

8.7 Local AI tools, coding agents and tool-server isolation

Protect developer/operator workstations as well as internet endpoints. An AI tool running as the same operating-system user can generally read what that user can read. Repository instructions and an agent's stated read-only intent are not an OS security boundary. This review does not establish that current workstations or tools already have the following isolation.

Run untrusted/third-party agents in a separately administered low-privilege account, VM or appropriately hardened sandbox with an approved repository-scoped workspace and synthetic fixtures. Prefer no production connectivity or secrets. Do not mount the home directory, production document/media folders, SSH/cloud credentials, host-management sockets or broad filesystem roots into that workspace. Restrict egress and host access; a container with a privileged host socket is not isolated from its host.

Default-deny tool servers/connectors, including MCP (Model Context Protocol). Register and review tool capabilities, endpoint/operator identity, code/package provenance and update policy. Tool descriptions/results are untrusted input; a familiar name is not proof of identity. Do not auto-approve a new tool, remote shell, arbitrary filesystem access or a permission-expanding update. Require separate confirmation and authorization for any consequential action.

Keep release/signing identities and production deployment outside the agent's ambient credentials. Proposed patches go through normal review, security tests and approved CI/CD; an agent must not approve its own deployment or change the controls that constrain it. If software must operate with broad administrator access, record that residual risk explicitly rather than label it sandboxed.

8.8 Detection, containment and assurance boundaries

Correlate authentication failures, client registration changes, cumulative access, export spikes, scope denials, unexpected destinations, tool/worker changes and cost reservations through restricted operational evidence. Do not export raw documents, prompts or credentials to an unapproved security/AI analytics service. Automated response must be bounded and reviewed; do not let attacker-controlled signals trigger unlimited account lockouts or disable the whole PMIS.

Provide independently authenticated, durable containment for subject/session, client/agent, project, source, provider and whole-AI scope. Enforce it at every remaining protected checkpoint, not only on the public ask button. Preserve approved business operations while containing AI-specific abuse; a compromised human identity also needs ordinary identity/session incident response. Section 20 defines drills and controlled reopening.

9. Ingestion, file safety and provenance

9.1 Separate repository storage from AI eligibility

ConPro may store a wider set of files than RAG can safely interpret. A stored file is not necessarily indexed, ready, permitted for export or understood. Unsupported files remain available through ordinary authorized ConPro handling, with explicit `unsupported/not_indexed` state for AI.

Current RAG supports text extraction from PDF, DOCX and TXT, selected image OCR, and separately approved AI image descriptions. Text-bearing PDFs can work; scanned-PDF OCR, reliable tables and verified CAD/BIM/drawing understanding must not be claimed from those capabilities.

The applications have different size envelopes: ConPro's large-file handling does not imply RAG can parse the same sizes. The standalone RAG upload cap is 200 MiB by default; visual description has a 20 MiB/25-million-pixel limit. Set a conservative integration envelope based on measured parser resources.

9.2 Isolated processing pipeline

1. Accept only server-authorized immutable versions from approved exporters.
2. Validate actual byte count, extension/signature/content type, digest and manifest authenticity; filenames never determine trusted staging paths.
3. Quarantine and scan, with explicit policy for malware, password protection, corrupt archives, embedded objects, decompression bombs and active content.

4. Run parsers/OCR in restricted workers with CPU, memory, wall-clock, disk and process limits. A Python thread is not a hostile-file security boundary.
5. Produce structured extraction blocks with real page/section/row/cell provenance, quality/completeness indicators and a versioned parser profile.
6. Review unsupported/low-quality extraction explicitly; do not call an empty or truncated parse an indexed success. Never execute macros, attachments or code.
7. Stage embeddings/lexical data; publish only the validated complete generation.
8. Recheck current ingest/source rights before dispatch/publication; clean owned temporary files on every terminal path and after crash recovery.

Use explicit states: accepted, quarantined, unsupported, parsing, quality_review, indexing, ready, failed, stale and revoked. "Queued" is not ready. Error details shown to users must come from allowlisted codes, not parser/provider exceptions. Dead letters need restricted access; they must not become an unbounded raw-file or confidential-prompt archive.

9.3 Visual descriptions are derived interpretations

The current opt-in path normalizes an image and uses OpenAI, with an explicit external-processing choice and an unverified label in indexed chunks. This is useful for search, not proof of dimensions, asset identity, engineering intent, table relationships or correctness. A human-readable warning does not make an inaccurate model description safe for certification.

Approve source classification, processor, model, jurisdiction, retention and cost separately. API `store=False` is not contractual zero retention or a training/residency guarantee. Minimize transmitted content and consider a separately evaluated private model only when justified by requirements.

10. AI correctness, abuse and business safety

Treat retrieved text/images as untrusted evidence. Instruction delimiters and injection detection reduce risk but cannot guarantee a model will ignore every malicious instruction. Keep tools and business writes unavailable to the model.

Require exact source/version attribution and a context ledger, bounded candidate and token budgets, citation-membership validation, claim/evidence checks, uncertainty and an explicit insufficient-evidence outcome. Citation membership does not prove a claim is true; lexical overlap and domain classification are heuristics, not semantic verification.

No external-knowledge prefix, synthesis classification or provider-error fallback may bypass the integration's policy, provenance or release gates. The existing standalone text-answer function cannot be reused unchanged as the ConPro trust boundary. Use a typed integration evidence path instead of dropping metadata and later guessing source identity from plain text.

For numeric answers, use approved read-only ConPro calculation/report adapters. Validate values, units, currency, period, rounding and as-of time against typed receipts. Do not run LLM-generated SQL, accept arbitrary DB connections or let a model recalculate contractual amounts.

No autonomous issuance, payment, approval, incident closure, account change, baseline modification or access grant is included. Later draft assistance must use existing forms/workflows with explicit human review and normal validation.

10.1 Prompt injection must not become tool or browser authority

Treat document text, OCR, filenames, metadata, tool responses and model output as data, never permission to change instructions, role, source scope, model, processor, callback destination or execution stage. Do not place live credentials in model context or let a model choose a network destination.

No shell, code execution, browser automation, arbitrary SQL, file mutation or business-write tool is exposed to the model in this design. A future tool proposal must authorize each exact action independently of the model's request and bind any approval to immutable arguments/current policy, not a reusable general "allow agent" switch.

Disable automatic fetching of model-generated remote images, previews and links. Validate citations against the server-owned evidence ledger and serve protected source links through the existing authorized path. Sanitize generated markup and apply reviewed external-navigation rules; do not rely on a model refusing a malicious instruction. The acceptance test is absence of unauthorized data or side effects even when the generated text follows the injected instruction.

11. Availability and graceful degradation

11.1 Separate service objectives

The following are **proposed review targets**, not measured current performance, contractual promises or evidence that current Compose satisfies them. Owners must approve workload definitions, exclusions and the cost of meeting them.

Service/indicator	Initial proposed objective	Definition and release evidence
Core PMIS availability	99.9% monthly	Successful eligible business requests/eligible requests; include user-visible planned disruption unless explicitly contracted otherwise. External uptime probes and business transactions.
Interactive non-AI reads	p95 <= 1 s; p99 <= 3 s	Representative bounded project/module reads, measured at agreed user geography; large downloads/reports measured separately.
Ordinary transactional writes	p95 <= 2 s	Representative validated writes excluding bulk transfer; preserve transactional correctness.
AI request completion	99.5% monthly	Authorized, eligible, supported requests reaching valid answer or honest abstention; provider/policy/audit failures counted separately and not hidden.
AI end-to-end latency	p95 <= 15 s; p99 <= 30 s	Approved bounded context/model under measured quota. Must implement a real overall budget; current per-network timeout alone does not satisfy it.
Authorized retrieval	p95 <= 1.5 s	Policy generation, allowlist size and corpus profile recorded; no unauthorized candidates as a speed shortcut.

Service/indicator	Initial proposed objective	Definition and release evidence
Revocation enforcement	No unauthorized later release after the authoritative revocation is observed by required checks	Adversarial revoke-during-query/history tests. Physical deletion has a separate SLA.
Index freshness	p95 <= 5 min for eligible pilot files	From durable source commit to exact-generation ready; superseded versions unavailable meanwhile.
HA failover	<= 5 min recovery, within approved same-region data-loss policy	Fenced failover drill for DB, object access, policy and routing.
Disaster recovery	Core RTO <= 4 h; cross-site RPO <= 5 min, subject to proof	Full authoritative DB/files/keys/policy recovery drill; both metadata and blobs must meet RPO.
AI-derived rebuild	<= 24 h for the agreed initial corpus	Measured rebuild and revalidation; core PMIS works without AI.

At 99.9% a 30-day month has 43.2 minutes of error budget; 99.5% has 216 minutes. Use consistent definitions and monitoring windows. Correct authorization denials are not outages, but unexpected denials, overload of eligible traffic and stale/ unavailable dependencies must not be silently removed to improve reported SLOs.

11.2 Failure containment matrix

Failure	Core PMIS behavior	AI behavior
Model timeout/outage/quota	Continue normal permitted work.	Bounded error/abstention as appropriate; no unapproved provider fallback.
RAG/vector/lexical outage	Continue normal permitted work.	Explicit unavailable or contract-approved dense-only mode, never pretend hybrid succeeded.
ConPro policy callback unavailable	Existing operations follow their existing policy dependency rules.	Deny dispatch/release/history; no cached-permission fail-open.
Identity/account authority unavailable	Do not invent new access or bypass security.	Deny new unverified operations. Approved emergency access is a separate controlled process.
Index behind source	Documents/workflow remain authoritative.	`index_not_ready/stale`; never answer from a withdrawn "current" revision.
Audit unavailable	Follow approved per-operation audit policy; critical mutations cannot silently lose required evidence.	Pilot release requires durable minimal audit, otherwise explicit unavailable.
Queue worker lost	Ordinary PMIS remains usable; source mutation already has durable outbox state.	Retry after lease expiry with idempotency and sequence fencing.
Blob missing/corrupt	Explicit document unavailable/integrity alert; preserve metadata/history.	Withhold dependent evidence and answers; no blank-file success.
Region loss	Execute approved DR/fencing procedure.	Disable AI until policy, source generations and approved egress are revalidated.

Failure	Core PMIS behavior	AI behavior
Malicious file/tenant flood	Quarantine/reject and preserve capacity for other users.	Per-subject/project budgets and isolated workers; no shared unbounded backlog.

11.3 Health, rollout and shutdown

Distinguish liveness, readiness and degraded-feature status. Do not make ConPro's core readiness depend on a model provider. RAG readiness requires its own essential local dependencies; optional capabilities report separate status. Use protected detailed diagnostics and minimal public health signals.

Rollouts must drain admitted work, stop new leases, preserve outbox receipts and record uncertainty where a provider continues after a local timeout. Do not hold SQL/index transactions while waiting for AI. Never mass-retry billable provider requests because a reverse proxy timed out.

11.4 Accessible and resilient user access

Availability and accessibility are distinct. A running service can still be unusable for a disabled user, a mobile user or a project site with poor bandwidth. The proposed accessibility target is **WCAG 2.2 Level AA** for the approved end-to-end workflows, subject to the owner's applicable legal requirements. Do not claim current ConPro or this generated PDF conforms without an audit.

Area	Proposed requirement and acceptance evidence
Keyboard and assistive technology	Complete login, project selection, upload/status, ask, citations and history without a mouse. Use semantic landmarks/headings, labelled controls, logical focus, visible/unobscured focus, accessible dialogs and no keyboard traps. Test with representative screen-reader/browser combinations.
Visual and mobile presentation	Meet applicable AA contrast criteria: normally 4.5:1 for ordinary text, 3:1 for large text and relevant non-text UI. Support 200% text resizing and reflow at 320 CSS pixels, with standard exceptions for inherently two-dimensional content. Do not encode status only through color; test touch-target requirements and orientation.
AI and asynchronous feedback	Announce meaningful progress/completion/error states accessibly without reading every streamed token. Offer a usable non-streaming result and accessible cancel/retry/status actions. Citations, unsupported-format notices and unverified-image warnings must be understandable without icons or visual position.
Authentication and timeouts	Support accessible authentication, password managers and permitted paste. Warn about time limits and allow extensions where required and safe; otherwise provide accessible reauthentication. Never extend a revoked grant or expired authorization handle to accommodate UI timing.
Documents and alternatives	Preserve document language, meaningful headings and table structure in approved generated exports; provide text equivalents for visual information. Label AI image descriptions unverified: they are not automatically an adequate accessibility alternative for an engineering drawing. Require human-verified alternatives where needed.

Area	Proposed requirement and acceptance evidence
Slow or interrupted connectivity	Minimize initial payloads, paginate large results and show honest offline/retry states. Use bounded idempotent submissions and owner-protected job status so reconnecting does not duplicate a paid generation or business mutation. Separately approve resumable uploads with integrity and authorization checks.
Private/offline access	No implicit offline replica, browser answer archive or public cached document. An offline feature needs separate classification, encrypted storage, device/expiry policy and explicit acceptance that live revocation cannot be guaranteed while disconnected. Clear sensitive transient state on logout/account switch.
Accessible support	Provide plain-language errors, recovery guidance, consistent help and a usable support route. Train users on AI uncertainty and source verification; accommodate language and locale needs without changing authoritative units, dates or calculations.

Accessibility acceptance combines automated checks with manual keyboard, screen-reader, zoom/reflow, mobile and representative user testing. Automated scores alone do not establish WCAG conformance. Record the tested workflow, browser/assistive technology, criterion, defect, owner and retest evidence. Any current limitation needs a supported alternative and an explicit remediation decision, not an unqualified compliance claim. ConPro UI changes still require separate approval; this section only defines review requirements.

12. Disaster recovery and backup design

12.1 Recovery assets and separation

Back up the authoritative DB, immutable files/version manifests, audit evidence, policy/tombstone generations, configuration and key-recovery material. Derived indexes may be rebuilt, but reconstruction needs retained permitted sources, profiles and integrity receipts. If policy/eligibility is lost, an index dump is not permission to expose historical content.

Use encrypted, access-separated backups with an immutable/offline recovery copy appropriate to the threat model. Monitor both backup freshness and restore eligibility. Replicas copy accidental deletion and ransomware too. Key backup must not depend solely on the encrypted system it must unlock. Do not destroy recovery keys before approved retention/hold obligations end.

PostgreSQL PITR requires a compatible base backup and complete required WAL. A logical dump is not a substitute for that WAL-based recovery chain. Protect backup credentials from application identities; restrict bulk exports.

12.2 Restore acceptance sequence

1. Declare incident, define recovery point and isolate restoration from normal traffic/provider egress. Fence old writers; record the recovery authority.
2. Restore keys/secrets through the approved recovery process, then identity/ policy prerequisites and PostgreSQL to the selected verified point.
3. Restore corresponding object versions/manifests; compare database references, checksums, object counts and source-generation consistency. Missing blobs remain explicitly unavailable, not replaced by a newer/older arbitrary file.

4. Replay approved post-backup revocations/tombstones from a separately protected ledger or keep the restored corpus closed until fully reconciled.
5. Verify ledger/report totals, workflow state, exact-version downloads, authorization denials, audit continuity and critical business smoke tests.
6. Resume core PMIS through controlled routing only after its readiness approval.
7. Rebuild/restore derived indexes, reapply current policy and invalidate stale handles/caches/history. Revalidate processors before enabling AI.
8. Measure achieved RPO/RTO and object/record loss, record exceptions and obtain owner signoff. A stopwatch without correctness tests is not a recovery drill.

An old backup can contain deleted/revoked material. Backup restoration must not resurrect its ordinary visibility. Cross-region object replication and database replication must satisfy a joint recovery-point contract, not separate optimistic numbers. Test region loss, key-service loss and compromised-backup scenarios.

12.3 Drill cadence and ownership

Proposed cadence: automated restore verification monthly, end-to-end DR exercises quarterly and before significant storage/key/major-version changes. Adjust with the owner after business-impact analysis. Record restore size, throughput, dependency order, authority checks, recovery keys, failback and runbook contacts. Define controlled offline business continuity separately; offline copies cannot promise live revocation and must be explicitly classified, encrypted and time-bound.

12.4 Modern backup engineering and ransomware resilience

Use **3-2-1-1-0 as a proposed planning baseline**: three copies including the primary; two independent storage media/services; one off-site copy; one immutable or offline copy; and zero unresolved verification errors in the tested recovery set. Copies must span meaningful failure/administration domains. Three buckets controlled by the same compromised application credential do not meet the intent. This rule is not a zero-data-loss or zero-risk guarantee.

Strategy	Required design and proof
Continuous recovery	Automate compatible PostgreSQL base backups plus continuous WAL archiving/PITR. Monitor the latest restorable transaction and archive gaps, not merely backup-job success. Choose base-backup frequency from measured restore time, volume and recovery objectives.
File and manifest recovery	Back up/version original objects and manifests with coordinated database recovery points. Monitor replication/backup lag independently; the joint RPO is limited by the least recoverable required asset. Storage snapshots alone do not establish application consistency.
Immutable isolated copies	Use approved retention locks/WORM or offline media, separate backup administration and MFA/dual control for destructive changes. Production/RAG credentials must not delete backups or alter their retention. Test policy enforcement and account compromise containment.
Encryption and key survival	Encrypt in transit and at rest under approved keys; separate key access from bulk backup access. Exercise key recovery and rotation with old recovery sets. A surviving encrypted backup without a recoverable key is unusable.

Strategy	Required design and proof
Automated verification	Check checksums, manifests, WAL continuity, retention state and restore eligibility. Restore into an isolated environment and verify records, exact files, business invariants and access denials. Quarantine a failed recovery set and alert a named responder.
Efficient, governed lifecycle	Use supported incremental/snapshot mechanisms, compression/deduplication and tiering only after restore testing. Approve daily/weekly/monthly retention classes, legal holds, deletion lag, costs and retrieval times; do not invent a universal retention period.
Clean cyber recovery	Retain enough approved history to recover before a detected compromise. Scan/review candidate restores in isolation, rotate compromised credentials, patch the entry point and replay current revocations before release. An immutable infected backup is still infected.
Recovery evidence and exercises	Keep restricted restore receipts, achieved RPO/RTO, backup size/age, missing objects, key checks and owner signoff. Exercise loss of a zone/region, storage account, identity/key service and backup administrator, plus controlled failback.

Use storage-native replication/snapshots as layers, not replacements for independent backups. Document the cost and recovery delay of cold/archive tiers and test retrieval before relying on them for the four-hour proposed RTO. Loss of an AI vendor must not prevent authoritative PMIS restoration.

13. Performance and capacity engineering

13.1 Establish the workload, not a marketing user count

Collect registered users, active users, concurrent connections, requests/second, active AI generations, upload bytes/second, document/page distributions, sources/ chunks per project, policy-query cost, token usage and geographic latency. One million accounts is not one million concurrent provider calls.

For planning, Little's law gives average active work approximately arrival rate times average service time in a stable system. At 20 admitted AI requests/second and an average eight-second service time, roughly 160 active operations are needed before headroom. This is arithmetic, not a benchmark or sizing approval. Provider token/rate quotas, RAM, parser CPU, DB locks and egress can dominate.

13.2 Practical capacity models

```
raw embedding bytes = chunk count * embedding dimensions * bytes per value
vector planning example = 1,000,000 * 384 * 4 = 1,536,000,000 bytes

total derived storage =
    vectors + text + metadata + lexical index + ANN index + receipts/history
    + WAL/staging + growth + replicas/backups

connection budget >= sum(application pools + workers + reports + maintenance)
but total pool maxima < tested DB capacity minus operational reserve

provider token budget = admitted questions/minute * measured tokens/question
image/provider costs require their own measured accounting
```

The vector example excludes all indexes/metadata/replicas and is not total capacity. Measure real data, index expansion, backup windows and reindex working space. Alert before headroom is exhausted; reserve capacity for repair.

13.3 Optimize without weakening isolation

Profile policy, DB query plans, hydration/serialization, embedding CPU, retrieval, reranking, context size, provider time and frontend network separately. Eliminate proven N+1 access checks through equivalent request-local batching; do not bypass object/field decisions or reuse stale authorization.

Use selective indexes, bounded pagination and explicit fields. Move large reports/exports/ETL off interactive workers under separate quotas. Large ConPro uploads must not occupy all ordinary request workers; a 600-second worker timeout alone is not scalable upload architecture.

Use bounded connection pools rather than an unbounded pool per replica. Current RAG's single connection/local lock is not a distributed pool. Read replicas can serve approved non-authoritative reads, but policy/currentness checks must meet freshness requirements and may require primary/consistent reads.

Keep strict candidate/context/token caps and statement budgets. The existing pilot proposals of 200 source references, 10,000 eligible chunks, 15 candidates per branch, 30 union candidates and five context blocks are safety review caps, not measured enterprise sizing. Oversized scopes return explicit narrowing requests; they do not trigger unfiltered searches.

14. Scalability and deployment stages

Stage	Appropriate architecture	Exit condition before expanding
S0: current/local	Existing ConPro deployment and one RAG API process; separate AI flag.	Storage/policy/backup baseline verified; no production HA claim.
S1: controlled pilot	One approved project, <= 20 selected ordinary documents; durable outbox and bounded worker.	Permission parity, revocation, provenance, restore and real latency/cost tests pass.
S2: production foundation	Private integration, managed persistent storage, operational metrics, quotas and approved DR.	Core remains independent of AI; operator and data-owner acceptance.
S3: horizontal RAG	Stateless request replicas after jobs/admission/history/generations/metrics are externalized.	Multi-worker crash/retry/revocation/cross-identity tests and distributed quota evidence.
S4: larger portfolios	Measured partitioning, index tuning and workload-class isolation.	Correct cross-project policy, capacity and noisy-neighbor containment.
S5: regional expansion	Initially an approved primary + DR region; later regional read/query placement if justified.	Residency, consistency, failover/failback and economic evidence; no casual active-active writes.

ConPro's existing multiple Gunicorn workers and RAG's one-worker restriction are different facts. Do not reduce or multiply one merely because of the other.

Before S3, externalize **all** relevant RAG state: durable ingestion operations/ leases, source generations/tombstones, authorization handles, global and per-subject admission/provider quotas, required audit/history, idempotency, cache invalidation and long-horizon metrics. A broker is an option, not a substitute for durable business outbox and idempotent handlers.

Autoscaling must consider queue age, provider quotas, CPU/memory and measured service time, not CPU alone. Raising replicas while the provider is throttled increases cost/backlog without capacity. Bound backlog and apply fair admission. No tenant can consume every parser, DB connection or generation slot.

Shard only after measurement and operational readiness. Namespace/project placement is server-owned, migration is fenced and reversible, and no query silently broadens across shards. Shared versus dedicated tenant infrastructure is a risk/cost decision; the current ConPro deployment must not be assumed to already contain an enterprise multi-tenant isolation model.

15. Geography, latency and consistency

Distance adds network round trips between user, API, policy authority, DB, storage and model. For sequential remote operations, even a modest RTT is multiplied; bandwidth also controls large-file transfer. Moving only the UI does not remove backend/model latency.

Place application, authoritative DB/policy and derived store near one another initially. Use a CDN for public static assets, not authenticated answers or private documents by default. Keep-alive, compression and safe batching reduce overhead, but TLS verification and final authorization cannot be skipped.

Regional processing requires approved residency for originals, embeddings, logs, backups, support access and model calls. A provider's brand or a DNS name alone does not prove the request stays in an approved jurisdiction.

Avoid asynchronous replicas for decisions requiring current revocation. If a region cannot verify the authoritative generation, deny/withhold AI rather than serve stale private answers. An isolated region may offer only explicitly approved business continuity functions, not invent a permission fallback.

Use explicit UTC timestamps with user/project-local presentation, agreed effective-date timezone and deterministic currency/calendar rules. Synchronize clocks and detect skew; token expiry, leases and audit ordering depend on it.

16. Observability, audit, operations and cost

16.1 Signals and privacy

Collect request rate/errors/latency by operation, admission rejection, queue depth/oldest age/lease recovery, parser errors, generation lag, missing/corrupt objects, DB pool waits/locks/replication/WAL, provider latency/quotas/tokens/cost, revocation propagation, denied releases, deletion backlog and restore freshness.

Use safe low-cardinality metric labels; never put questions, document names, user IDs, source text, handles or secrets into metrics. Restricted traces can carry opaque correlation IDs under retention policy. Scrub client libraries, reverse proxies, crash dumps and APM capture as well as application logs.

The existing RAG collector is bounded and in-process. Its retrieval score is a lexical heuristic, not a verified quality benchmark or a month-long availability measurement. Export metrics to an approved backend and add outside-in probes.

16.2 Minimal audit and evidence chain

Record trusted actor/service identity, authorized project, operation/request ID, safe outcome, source/version count or allowed opaque references, generation/ profile, timing and minimal processor/cost receipts. Register event vocabulary through ConPro's actual audit mechanism; the companion documents' example `AI_*` and `RAG_*` names require one approved mapping, not two accidental catalogs.

Do not store raw prompts, answers, confidential snippets, tokens, DSNs or provider errors in generic audit comments. Do not treat client-claimed forwarded headers as proven identity. Use append-oriented access, integrity verification, restricted exports and alerts for tampering; “immutable” storage still requires administrator/key compromise analysis.

16.3 Alerting and economics

Assign owners and response severity to fast/slow SLO burn, policy bypass indicators, unusual exports, failed audit integrity checks, expired certificates, backup gaps, lost deletion events, queue growth and provider spending anomalies. Rate-limit alerts without silently suppressing critical evidence.

Enforce per-user/project and global daily cost/request/token budgets, plus separate ingestion/image/reindex budgets. Track successful abstention, failure, cancelled work that still bills and retry duplication. No automatic fallback to an unapproved/cheaper processor or cheaper authorization mode.

16.4 Atomic resource and spending admission

Enforce baseline shared budgets before the pilot, not only when adding replicas. At minimum, query generation, image processing, embeddings and reindexing each need per-subject/client/project and global limits, bounded concurrency, payload/ token caps and fair capacity for other users. Separate control-plane/core PMIS capacity from AI work. If the required admission ledger is unavailable, deny new billable work rather than use an unbounded local fallback.

Use a durable reservation protocol:

1. Authenticate and authorize the operation; bind its idempotency key to trusted subject/client, project, canonical request, scope and processor profile. Reuse with different content is a conflict, not a free second request.
2. In one transaction, reserve bounded work/disclosure/cost allowances against all applicable ceilings using fixed-point units, safe concurrency controls and unique operation identity. The same attempt cannot reserve twice.
3. Persist dispatch intent; recheck current policy/containment before issuing the bounded provider call. A rate limiter alone does not reserve money.
4. Settle from trusted usage/dispatch receipts. A timeout, crash or cancellation can still bill; keep uncertain reservations charged/held until reconciled. Do not release them merely because a lease or HTTP timeout expired.
5. Give each paid retry its own bounded reservation and apply the one overall deadline. No automatic retry after an uncertain outcome unless the provider contract supports the required idempotency or explicit reconciliation resolves it.

Use an approved upper-bound tariff/payload model for reservations and reconcile price changes. If a safe bound cannot be established, do not claim a strict spending ceiling; block that operation or obtain an explicitly limited exception. Provider account-level limits, if enforceable, are defense in depth; billing alerts alone are not hard limits. Compromised credentials used outside this gateway remain an incident risk, requiring separate identities and revocation. No exactly-once external billing guarantee is claimed.

17. Critical reference implementation patterns

All fragments below are proposed reference material, not installed code. They illustrate narrow contracts. They are not a complete connector or production migration. Review schema, authentication, policy adapters, budgets and tests before implementation. The companion integration plan contains the fuller route/source/evidence contracts.

17.1 Fail-closed comparison of authoritative receipts

```python
from dataclasses import dataclass
from datetime import datetime


@dataclass(frozen=True)
class PolicyReceipt:
    subject_id: str
    session_id: str
    namespace: str
    project_id: str
    request_id: str
    question_digest: str
    sources_digest: str
    policy_generation: int
    source_generation: int
    processor_profile: str
    expires_at: datetime


def require_unchanged_receipt(
    issued: PolicyReceipt, fresh: PolicyReceipt, now: datetime
) -> None:
    if now.tzinfo is None or issued.expires_at.tzinfo is None:
        raise ValueError("Timezone-aware policy times are required.")
    if fresh.expires_at.tzinfo is None:
        raise ValueError("Timezone-aware policy times are required.")
    if now >= issued.expires_at or now >= fresh.expires_at:
        raise PermissionError("Authorization expired.")
    if (
        issued.subject_id, issued.session_id, issued.namespace, issued.project_id,
        issued.request_id, issued.question_digest, issued.sources_digest,
        issued.policy_generation, issued.source_generation, issued.processor_profile
    ) != (
        fresh.subject_id, fresh.session_id, fresh.namespace, fresh.project_id,
        fresh.request_id, fresh.question_digest, fresh.sources_digest,
        fresh.policy_generation, fresh.source_generation, fresh.processor_profile
    ):
        raise PermissionError("Authorization or source state changed.")
```

The fresh receipt must come from a live, authenticated, authoritative policy evaluation, including all object/field/export/processor decisions. Equality does not authenticate a forged receipt or evaluate permissions. Generate digests from canonical server-owned source manifests; never from browser claims. Bind phase/handle-use rules in the durable query state as well. A recheck cannot recall text already sent to a provider or already displayed to a user.

17.2 Durable outbox claiming with bounded leases

```sql
WITH claimable AS (
    SELECT id
    FROM conpro_ai_outbox
    WHERE (
        state IN ('pending', 'retry') AND available_at <= CURRENT_TIMESTAMP
    ) OR (
        state = 'leased' AND lease_expires_at <= CURRENT_TIMESTAMP
    )
    ORDER BY available_at, id
    FOR UPDATE SKIP LOCKED
    LIMIT %(batch_size)s
)
UPDATE conpro_ai_outbox AS operation
SET state = 'leased',
    lease_token = %(lease_token)s,
```

```
    lease_expires_at = CURRENT_TIMESTAMP
        + %(lease_seconds)s * INTERVAL '1 second',
    attempts = operation.attempts + 1
FROM claimable
WHERE operation.id = claimable.id
RETURNING operation.id, operation.source_key, operation.desired_sequence,
          operation.lease_token, operation.lease_expires_at;
```

This table/worker is proposed. Insert its event in the same transaction as the owning ConPro mutation; an after-commit notification is only a wake-up hint. Bind parameters, enforce positive bounded batch/lease sizes and cap attempts with a restricted dead-letter policy. Lease tokens must be unique per claim.

Publication must additionally lock/check current source sequence and expected lease token, then atomically publish the index generation/receipt. A lease alone does not stop a slow stale worker from writing after expiry. No cross-service exactly-once guarantee or distributed transaction is claimed. Reconciliation and idempotency are required even with a broker.

17.3 Illustrative RLS guard, not the whole policy

```
CREATE ROLE rag_query NOLOGIN NOSUPERUSER NOBYPASSRLS;
REVOKE ALL ON SCHEMA rag_derived FROM PUBLIC;
GRANT USAGE ON SCHEMA rag_derived TO rag_query;
GRANT SELECT ON rag_derived.chunks TO rag_query;

ALTER TABLE rag_derived.chunks ENABLE ROW LEVEL SECURITY;
ALTER TABLE rag_derived.chunks FORCE ROW LEVEL SECURITY;

CREATE POLICY scoped_query ON rag_derived.chunks
    FOR SELECT TO rag_query
    USING (
        namespace = current_setting('app.namespace', true)
        AND project_id = NULLIF(current_setting('app.project_id', true), '')::uuid
    );
```

Schema/table/column/role definitions are proposed prerequisites. Provision the actual login identity separately and keep it non-owner without inherited administrative privileges. Set transaction-local context only after trusted authorization, with parameterized database calls and pool-reset tests. Missing settings deny matches; invalid UUID context errors fail closed. Still join exact authorized source versions before ranking. This guard does not protect against a compromised service allowed to choose arbitrary context and does not replace ConPro record/field permission checks.

17.4 End-to-end budget without hidden extension

```
from dataclasses import dataclass
import math
import time


@dataclass(frozen=True)
class Deadline:
    expires_at: float

    @classmethod
    def start(cls, seconds: float):
        if not math.isfinite(seconds) or seconds <= 0:
            raise ValueError("Deadline must be finite and positive.")
        return cls(time.monotonic() + seconds)

    def remaining(self, stage_limit: float) -> float:
        if not math.isfinite(stage_limit) or stage_limit <= 0:
            raise ValueError("Stage limit must be finite and positive.")
```

```
        budget = self.expires_at - time.monotonic()
        if budget <= 0:
            raise TimeoutError("Request deadline exceeded.")
        return min(budget, stage_limit)
```

Apply one request budget to each policy/retrieval/provider stage; never reset it on retry. Library network timeouts may apply per socket operation, not total wall time. Enforce true deadlines/cancellation at the executor/service layer and account for work continuing remotely. Preserve admission release in `finally`; only bounded idempotent retries are eligible.

17.5 Restore and release evidence receipt

```
{
  "contract_version": 1,
  "environment": "isolated-staging",
  "change_id": "REVIEW-REQUIRED",
  "source_recovery_point": "OWNER-APPROVAL-REQUIRED",
  "database_restore_verified": false,
  "file_versions_verified": false,
  "keys_recovered_under_dual_control": false,
  "current_policy_and_tombstones_replayed": false,
  "cross_project_denial_tests_passed": false,
  "financial_and_workflow_checks_passed": false,
  "achieved_rpo_seconds": null,
  "achieved_rto_seconds": null,
  "core_release_approved": false,
  "ai_release_approved": false
}
```

This is an illustrative evidence shape, not a successful restore. Store signed/ access-controlled results and human approval through the existing change process. A script must not turn missing/null evidence into a passing default.

17.6 Illustrative agent-defense policy contract

```
{
  "contract_version": 1,
  "status": "PROPOSED_NOT_INSTALLED",
  "integration_enabled": false,
  "unregistered_service_and_delegated_clients": "deny",
  "authorization": {
    "current_conpro_policy_required_for_all_clients": true,
    "delegation_requires_current_user_and_client_and_task_grants": true,
    "caller_claimed_agent_or_user_identity_is_trusted": false,
    "bot_score_is_authorization": false
  },
  "capabilities": {
    "business_writes": false,
    "model_tools": false,
    "arbitrary_urls_or_sql": false,
    "bulk_export_without_separate_grant": false
  },
  "admission": {
    "shared_atomic_reservations_required": true,
    "missing_approved_limits": "deny_billable_or_bulk_operation",
    "uncertain_dispatch": "hold_reservation_until_reconciled"
  },
  "containment": {
    "authority_unavailable": "deny_protected_ai_operation",
    "checks": [
      "issuance", "dispatch", "publication", "release", "history"
    ],
```

```
    "persist_across_restart_rollback_and_restore": true
  }
}
```

This is a review artifact, **not configuration consumed by ConPro or RAG**. It does not detect browser automation, validate a token or implement a firewall. Implementation must use a strict versioned schema, reject unknown/contradictory fields, validate all approved limits and map every requirement to enforcement and tests. Missing evidence/configuration must never become an enabled default.

18. Implementation batches, ownership and rollback

Batch	Scope and accountable owners	Acceptance/stop condition
P0: decisions	Product, security, document control, commercial and operations approve classification, source/processor policy, authorized automation/delegation, bulk-use restrictions, SLO/RPO/RTO, legal retention and budget.	No integration code or production export before written decisions; name owners and approve abuse/revocation thresholds.
P1: storage/recovery	DBA/storage/operations resolve B01/B02, provision real roles/secrets, persistent media and backups.	Container replacement, exact-version integrity and full restore drills pass.
P2: deployment foundation	Platform team isolates ingress/egress/admin/tool workspaces, origin access and trusted identity; configures certificates, key recovery, credential lifecycle and durable containment.	Alternate-route/header/replay/secret-isolation tests and core availability pass; required security state survives restart/rollback.
P3: policy/contracts	ConPro/backend and security review extracted visibility parity, source registry, safe projections, scoped handles, client/delegation grants and cumulative-use rules.	Existing visibility/UI parity and approved abuse-policy behavior tested; subject/client/task intersection and revoked-identity denials pass.
P4: durable indexing	Backend/data team adds transactional outbox, leased workers, parser isolation, tombstones and fenced publication.	Crash/replay/order/deletion/duplicate tests and reconciliation receipts pass.
P5: read-only AI pilot	RAG/ConPro team wires exact scoped retrieval, dispatch/return validation, audit, safe citations and atomic resource/cost admission.	One approved project/<=20 ordinary documents; A-01 through A-12 pass; no unauthorized evidence; tested abstention, reserved cost and containment.
P6: measured hybrid	Retrieval team implements independent lexical branch and identity-based fusion only if approved.	Same eligibility/snapshot; meaningful evaluation improvement within latency/cost gates.
P7: history/modules	Data/module owners approve source-bound answer retention, module projections and deterministic facts.	Source revocation, restore, field privacy and numeric invariants pass per module.
P8: scale/HA	Platform/backend team externalizes remaining RAG state, pools connections and proves existing admission/containment at larger scale.	Multi-replica failover, noisy-neighbor, quota and recovery tests pass before worker multiplication; baseline security is not deferred to this batch.

Batch	Scope and accountable owners	Acceptance/stop condition
P9: geography	Operations/security/data owners approve region placement, residency and DR/failback.	Real regional latency, split-brain fencing and joint DB/object RPO evidence.

These are dependencies, not an instruction to execute. P3 may be designed while P1 is being validated; P5 release still depends on storage, policy, operations and durable-ingestion acceptance. No approval is inferred from a reviewed PDF.

Rollback disables new AI issuance/UI entry points and rejects integration queries before draining workers. Preserve source records, operation receipts, policy/tombstone generations and required audit. Do not roll back authoritative PMIS transactions, strip authentication or reopen stale source generations. Security revocations, agent registry denials, active containment and unresolved cost reservations survive rollback/restart; an old application version that cannot enforce them must keep protected AI routes disabled. Use expand/contract schema changes, compatible versioned readers and a tested rollback point. Do not erase data to make old code start.

ConPro/UI changes, including the proposed visibility-helper extraction, require separate approval. Keep implementation module boundaries small: policy, contracts, gateway, source export, outbox/worker and evidence validation. Avoid a second policy engine, duplicate per-module chatbots or a generic agent framework unless measured requirements justify them.

18.1 Agent-defense implementation work packages

These packages refine P0/P2-P5, not authorize a new deployment. Reuse the existing identity, permission, release and monitoring mechanisms. Suggested components are ownership boundaries, not a requirement to create a second policy engine.

Package	Implementation artifact and owner	Evidence before enablement
D1: inventory and policy	Security/product inventory routes, identities, service/tool capabilities, exposure and legitimate high-volume workflows; approve client/grant schema and limits.	Signed caller/action matrix and threat model; classified fixtures; no bot-score-based permission.
D2: ingress and identity	Platform/identity configure origin protection, trusted header chain, service roles, appropriate token/proof validation, MFA/recovery and credential revocation.	Network and replay tests from every approved deployment path; accessible normal-user behavior preserved.
D3: authoritative admission	Backend/security wire registered-client/task grants into existing ConPro checks and shared extraction/rate admission; no caller-owned scope.	Object/field/export parity, delegate/user intersection, rolling cross-route limits and failure-denial tests.
D4: provider and tool boundary	RAG/platform prohibit model tools/writes, constrain egress/rendering, isolate parsers/developer tools and enforce reserved resource/cost limits.	Injection causes no side effect; concurrent dispatch/crash tests respect budgets; denied secret/network access from an isolated test agent.
D5: persistent containment	Security/operations implement scoped deny state, enforcement checkpoints, safe alerts, recovery ledger and controlled reopening through separate administration.	In-flight/queued/history drills; state survives restart, rollback and restore; ordinary authorized PMIS operations remain isolated from AI-only containment.

Package	Implementation artifact and owner	Evidence before enablement
D6: independent assurance	QA/security validate A-01 through A-12, patch/release provenance, user-workflow regression and operator exercises.	Reviewer signs evidence and residual risks; feature remains disabled if a mandatory gate fails.

D2 follows D1; D3 follows approved D1/D2 contracts; D4 and D5 use those trusted identities and precede D6. Release requires every applicable package; do not ship only a WAF rule and call the remaining design implemented. Stage with synthetic fixtures, then an approved limited pilot; load-test attack simulations only in explicitly authorized isolated environments.

19. Acceptance tests and assurance evidence

No production release with an untested row marked “assumed”. Use synthetic or approved redacted fixtures and disposable explicitly designated databases. Separate test results, deployment inspection and owner risk acceptance.

Test group	Required cases and measurable result
Identity	Missing/invalid/expired/revoked keys/sessions; removed user; changed role; service audience mismatch. No unauthorized operation or payload.
Project/record/field	Same-name sources, foreign projects, expired memberships, confidential folders, company restrictions, incident sections and field/export denials. Exact policy parity.
Alternate paths	Standalone ask, internal search, citations, previews, history, feedback, metrics and exports cannot bypass ConPro corpus policy.
Existence leakage	Counts/snippets/errors/citations do not reveal unauthorized sources; review response timing and enumeration behavior.
Revoke during work	Withdraw before retrieval, during parsing, before provider dispatch, during generation, before return and before later read. Deny at required checks; no stale history resurrection.
Scope integrity	Forged/replayed handle, wrong subject/session/question/project/processor/profile/phase and expired clock-bound state. Fail closed.
File handling	Real type mismatch, corrupt/password-protected docs, malware, embedded active content, bombs, oversized/deep/animated inputs. No execution, resource escape or false ready state.
Formats	Text PDFs, scanned PDFs, DOCX paragraphs/tables, TXT, selected OCR/vision images and unsupported CAD/BIM/spreadsheets. Honest per-format quality/status.
Provenance	Real page/version/record locators; identical text from distinct sources; missing/changed blob or manifest; forged baseline. No fabricated source attribution.
Retrieval	Both branches search the identical authorized set/snapshot; no unfiltered retry or fusion that loses source IDs.

Test group	Required cases and measurable result
Generation	Injection, conflicting/insufficient context, malicious markup/links, refusal, partial output and synthesis bypass attempts. Bounded safe output/abstention with no tool writes.
Facts	Decimal/currency/time/calendar/period, restricted aggregates and stale figures. Numeric output equals deterministic receipts.
Queue/durability	Kill at mutation/claim/dispatch/publication/ack boundaries, duplicate/reordered events, expired leases and stale worker publication. Convergent idempotent state.
Deletion/history	Source withdrawal, user deletion, expiry, regrant, temporary revocation with no reads, holds and backup restore. No ordinary release of revoked content.
Web/session security	Object/field mutation checks, mass assignment, SQL injection, model-output XSS, CSRF, session rotation, account recovery, file headers and shared-browser logout. No integration-induced bypass.
Accessibility and site access	WCAG 2.2 AA review of complete approved workflows using automated and manual keyboard/screen-reader/zoom/mobile tests. Test slow links, disconnect/reconnect, idempotent retries and accessible errors without caching protected content offline.
Storage	Wrong mount detection, container recreation, missing file, full disk, checksum failure, object/WAL lag and key loss. Explicit errors and recoverable authoritative state.
Availability	Provider/index/audit/policy/network failures and recovery. Core PMIS isolated; AI does not fail open.
Performance	Agreed p50/p95/p99, throughput, DB/pool waits, queue age, token cost and geography at steady, burst and soak loads. Preserve permissions at every load level.
Fairness	Flood one project/user/class of upload. Other agreed workloads retain reserved capacity; bounded 429/503 behavior.
Multi-replica	Crash/failover/rolling upgrade, leader/scheduler duplication, pool-context contamination and distributed admission. No split-brain publication or cross-user leakage.
DR/failback	Rebuild DB/files/keys/policy/audit in isolation, replay revocations, compare business invariants and measure real RPO/RTO.
Backup isolation and cyber recovery	Attempt backup deletion/retention changes using application identities; simulate WAL gaps, corrupt/missing objects and lost keys. Prove protected copies and a clean coherent restore, not just successful snapshot creation.
Portability and exit	Export permitted records/files/manifests and reconstruct in a clean approved environment. Preserve identities, audit mappings and current restrictions; verify provider termination and deletion exceptions.
Supply chain	Dependency/image/model integrity and reviewed build provenance; parser patch and rollback procedure.

Test group	Required cases and measurable result
Operations/privacy	No secrets/raw prompts/images in logs/APM/errors; restricted diagnostics, audit-chain verification, alert routing and incident exercises.

Performance tests must include realistic authorization sets and distributions, not only one public document and a sleeping fake model. The earlier synthetic concurrency gain is not evidence for millions of users. Maintain regression tests for unchanged ConPro screens/workflows and feature-off behavior.

19.1 AI-agent and automated-intrusion release gates

No live attack or penetration test is authorized by this document. Use approved fixtures, capped traffic and disposable isolated environments. Record expected denial/allowance, deployment version, timestamps, audit receipts and owner signoff.

Gate	Required experiment and passing result
A-01: unknown automation	Try missing/unregistered/expired service or delegated identities and false agent claims. No protected payload, service privilege or expensive unauthenticated dispatch.
A-02: stolen credentials	Replay test sessions/tokens after logout, account disablement, refresh reuse and service/key revocation. Deny within the approved enforcement deadline; required live checks after authoritative deny cannot authorize a new protected operation.
A-03: delegated authority	Use an approved client with the wrong subject, task, action, project, source/field, processor or expiry. No permission beyond the current intersection; no query-to-ingest/admin escalation.
A-04: alternate ingress	Exercise direct origin/legacy routes, alternate hosts, wrong audiences, forged proxy/identity headers and mismatched sender proofs. Network/application denies; no bypass through streaming, downloads or internal services.
A-05: cumulative extraction	Use pagination, previews, downloads, history and repeated AI reads across replicas and approved test identities. Configured individual/aggregate limits and explicit export rights hold; slow extraction triggers reviewed signals. No claim to detect every colluding user.
A-06: injected instructions	Put adversarial instructions in approved text/OCR/metadata/tool-result fixtures. Even if the model follows them in text, there is no unauthorized source retrieval, command, SQL, write, provider change or callback.
A-07: output exfiltration	Supply generated remote images, tracking links, forged citations and malicious markup. No automatic fetch, script execution or private-data disclosure; valid protected citations still work.
A-08: resource and cost races	Run concurrent duplicate requests, paid retries, budget exhaustion, provider timeout and worker crash. No dispatch without a valid reservation; caps are respected and uncertain outcomes remain accounted for.

Gate	Required experiment and passing result
A-09: persistent containment	Commit subject/client/project/source/provider/global-AI denials while requests/jobs/history are active; restart/roll back/restore. Every remaining required check denies affected work; no automatic reopening or blanket shutdown of unrelated PMIS work.
A-10: local agent isolation	In a disposable workspace, attempt access to synthetic out-of-scope files/secrets, host controls, production-like denied endpoints and an unapproved tool server. OS/network/tool policy denies access; prompts are not counted as enforcement.
A-11: control/supply-chain change	Try unapproved tool/package updates, privilege expansion and deployment changes through the test agent identity. It cannot self-approve, access signing keys or weaken its own enforcement.
A-12: legitimate access and recovery	Test approved users/agents, assistive technology, necessary high-volume workflows and controlled incident reopening. Required work remains usable within approved restrictions; no silent visibility change or fail-open on ledger/identity outage.

20. Operator runbooks and incident response

Runbook	First safe actions	Recovery evidence
Suspected unauthorized AI disclosure	Disable affected AI issuance/egress, preserve restricted minimal evidence, revoke compromised identities and involve security/data owner.	Determine source/version/subjects/processors exposed; repair policy, verify denials, review notification obligations and authorize reopening.
Bad/missing persistent storage	Stop unsafe writes/restarts, preserve actual mounts/data; do not initialize a fresh cluster over uncertainty.	Verified backup, mapped data directory and staged restoration; no blind mount edits.
Source withdrawn or deletion backlog	Deny source eligibility first; stop dependent history release; inspect sequences/leases and retry bounded cleanup.	Tombstone/current policy applied, no stale replay, dependent artifacts removed under SLA.
Provider outage or cost spike	Enforce budgets/circuit isolation, stop unapproved retries and preserve normal PMIS operations.	Quota/cost receipts, bounded recovery, no silent provider or residency change.
Queue stuck or worker compromised	Stop new leases/affected worker identity; keep source authority intact.	Lease recovery and idempotent replay from durable outbox; compare source sequence and published receipt.
Database/region failure	Fence writers, invoke approved HA/DR authority and disable AI until policy restored.	Correctness plus measured RPO/RTO and controlled failback.
Key/certificate compromise	Revoke/rotate through separate authority; restrict network if necessary; protect forensic evidence.	Verify identity/audience failures and recovery-key availability; account for previously decrypted/exported data.

Runbook	First safe actions	Recovery evidence
Audit integrity failure	Restrict affected operations per policy; preserve chain/copies and separate operator credentials.	Root-cause investigation, independently verified continuity and explicit owner approval.
Suspected agent harvesting or stolen session	Contain the affected subject/session/client and revoke credentials; preserve restricted access/usage receipts. Do not rely on blocking one IP or one product name.	Verify denials across equivalent routes, identify already delivered data, repair the access path and obtain security/data-owner approval before reopening.
Compromised local AI tool/connector	Isolate its execution identity/workspace and network; revoke exposed secrets through a separate administrator. Do not let the suspected tool perform its own recovery.	Inspect permitted mounts, tool provenance and release artifacts; rebuild from trusted inputs, rotate affected credentials and retest D2-D6.

20.1 Scoped containment and controlled reopening

Containment must be operable without the affected model, agent, worker or gateway credential. A separate authenticated administrative path writes durable deny state, reason code, scope, generation, issuer and review time; raw source/prompt content is not required. Guard this path with least privilege, strong MFA and audited approvals. Broad containment needs the designated incident authority.

Check the current deny state before issuance, provider dispatch, index publication, result release, history and queued-job execution. New requests and in-flight work must not bypass it by changing routes/replicas. Stop new leases, fence affected publication and quarantine uncertain operations without deleting authoritative PMIS records. Preserve minimal protected forensic evidence.

Keep security denials and unresolved dispatch/cost state through deployments, rollback and recovery; replay post-backup denials from the protected recovery ledger. If current state cannot be established after restore, keep affected AI capabilities closed. No deny automatically expires into restored permission without the approved review policy.

Reopening requires repaired-control evidence, fresh credential/policy checks, denial/regression tests and named incident/data-owner approval. Preserve the incident history and explicitly scope any new grant; do not reuse revoked handles or revive scrubbed answers. Measure detection, containment enforcement and reopening times against owner-approved objectives.

Name primary and backup responders, escalation channels and decision authority before production. Test incident communications without confidential payloads. Post-incident actions must update threat assumptions, tests, training and controls, not only restart services.

21. Assumptions, limitations and future recommendations

21.1 Assumptions requiring explicit verification

Assumption	Owner and validation
There is an agreed deployment/company/project namespace.	Product/security; map actual identity and tenancy without assuming a missing tenant model.
Existing ConPro policy is the authority and can be extracted without drift.	ConPro/security; compare real object/field/export decisions and oversight exceptions.
Immutable source versions and protected digest baselines can be established.	Document control/storage; prove no in-place silent replacement.

Assumption	Owner and validation
Legal/contract schedules and provider/residency rules are available.	Data owner/legal/security; written decisions before export/retention.
Operations can fund and operate persistent storage, keys, backups and on-call.	Sponsor/platform; approved budget and completed drills.
The proposed SLO/RPO/RTO numbers match business impact.	Business owners/operations; workload and recovery evidence, not default adoption.
Each module has safe projections or deterministic fact adapters.	Module owners; field/lifecycle/processor approval and test fixtures.
Enough authoritative revocation history survives restore and temporary withdrawal.	Security/data; durable generations, replay tests and protected recovery ledger.
A representative evaluation corpus can be used lawfully and privately.	Data owner/QA; consent, redaction and restricted evaluation retention.

21.2 Limitations and residual risk

This is a source-informed design, not a penetration test, compliance certification, production deployment inspection, capacity benchmark or disaster-recovery result. Unknown deployment settings can invalidate assumptions. There is no “zero risk” release certificate.

No software can reliably distinguish every unauthorized AI agent from an authorized person merely by HTTP behavior. Stolen valid credentials, colluding users and agents with host-administrator privileges require layered identity, business-use, endpoint and operational controls. The PMIS cannot control every copy made on an external client’s device. Agent defenses here remain proposed until their deployment and A-01 through A-12 evidence are independently verified.

Model hallucination, prompt injection, social engineering, insider misuse, operator/key compromise, third-party outages and already disclosed information cannot be eliminated by this architecture. Defense in depth limits impact and improves detection/recovery; owners must accept remaining risk explicitly.

Cryptographic transport and hashes do not make a wrong policy or poisoned approved source correct. RLS does not replace application policy. A backup does not prove recoverability. A schema mirror does not prove independent hybrid retrieval. A generated image description does not prove drawing understanding. An answer cache/history TTL does not establish revocation correctness.

Current local FAISS retention, process-local admission/queue/metrics and existing text-only evidence handling do not satisfy the proposed enterprise connector. Source code can show intent; actual grants, storage durability, processor terms, infrastructure access and operations must be verified separately.

21.3 Future recommendations, gated by evidence

Priority	Recommendation	Prerequisite
Foundation	Resolve persistence/roles/backup and core operational observability.	B01-B08 evidence; no AI dependency for core PMIS.
Next	Safe controlled-document pilot and module-by-module expansion.	Policy/provenance/withdrawal/restore gates.
Next	Source-aware answer history and governed evaluation/feedback.	Durable per-source revocation and privacy schedules.
Next	Independent lexical+dense fusion and evaluated multilingual retrieval.	Identical authorized subsets, correct citations and measured quality gain.

Priority	Recommendation	Prerequisite
Medium	Better OCR, tables, locators and version comparison.	Real corpora, parser isolation and honest completeness metrics.
Medium	Dedicated/private model processing for restricted classes.	Security, residency, accuracy, cost and operations evaluation; not assumed safer merely because local.
Medium	Horizontal workloads, dedicated noisy-tenant pools and read optimization.	Externalized state, fair global budgets and measured database bottlenecks.
Later	Region-aware processing/DR and approved portfolio analytics.	Joint data/policy consistency, residency and tested failback.
Separate proposal	CAD/BIM reasoning, autonomous agents or business writes.	Domain validation, stronger tool/action authorization and explicit human/business approval; excluded here.

22. Coverage register and approval gate

This register makes omissions discussable and auditable. “Designed” means a requirement is specified here, **not** that a control is implemented or passing. Every owner must attach implementation and verification evidence before release.

Control	Coverage	Accountable owner	Required evidence
C-01	Data inventory, classification and ownership	Data owner	Approved asset map and derived-data labels.
C-02	Authoritative DB persistence/roles	DBA	Correct mounts, runtime privilege inspection and recreation test.
C-03	Original-file/version durability	Storage/document control	Immutable references, checksums and persistent recovery.
C-04	Identity/session/service lifecycle	Identity/security	Audience, expiry, revocation and rotation tests.
C-05	Project/record/field/export equivalence	ConPro/security	Existing-policy parity and denied cases.
C-06	Namespace/corpus isolation and bypass prevention	RAG/security	Every alternate route tested against ConPro-derived data.
C-07	Revocation/generation/phase checks	Both backend teams	Revoke-during-work, history and no-read temporary revocation tests.
C-08	Ingress/network/egress/mTLS	Platform	Deployed path/port/certificate/egress verification.
C-09	Secrets, KMS and recovery keys	Security/operations	Rotation, access audit and isolated key recovery.
C-10	File quarantine/parser isolation	Ingestion/platform	Malicious/bomb/oversize/timeout tests and containment.

Control	Coverage	Accountable owner	Required evidence
C-11	Source provenance/manifest integrity	Document control/data	Protected baselines and actual version locators.
C-12	Durable outbox, leases and idempotency	Backend/data	Crash/replay/order/fencing evidence.
C-13	Atomic index publication/deletion	Retrieval/data	Generation/readiness/tombstone consistency tests.
C-14	Authorized retrieval/fusion	Retrieval/security	Identical scoped branches and no membership leakage.
C-15	Prompt/model/output containment	AI/security	Injection, refusal, citation and abstention evaluation.
C-16	Deterministic financial/schedule facts	Commercial/schedule	Typed numeric invariants and workflow preservation.
C-17	Provider approval/privacy/residency	Data/legal/security	Contractual processing decisions and enforced routing.
C-18	Answer/feedback/cache retention	Data/backend	Owner/source reads, expiry, redaction, hold and backup rules.
C-19	Audit/trace/log integrity and privacy	Audit/security	Safe schema, trusted attribution and tamper tests.
C-20	Availability/health/degradation	Operations/product	Independent core and AI SLOs and failure drills.
C-21	Backup/PITR/object consistency	DBA/storage	Full restore with current revocations and correctness.
C-22	DR/failover/failback	Operations	Measured RPO/RTO, fencing and region/key-loss drill.
C-23	Performance/capacity/geography	Performance/platform	Real workload p95/p99, growth and RTT/token evidence.
C-24	Fair admission/rate/cost limits	Platform/product	Noisy-neighbor, quota and spending-bound tests.
C-25	Horizontal state/scheduler safety	Platform/backend	Externalized state, leader lease and pool isolation.
C-26	Secure SDLC/supply chain	Engineering/security	Review, SBOM, provenance, scanning and patch policy.
C-27	Deployment/migration/rollback	Release/platform	Single migration owner, compatibility and rollback drill.
C-28	Incident response/operator access	Security/operations	Named responders, time-bound privileges and exercises.
C-29	Legal hold/portability/exit	Data/legal/operations	Approved retention, exports, deletion and provider exit plan.

Control	Coverage	Accountable owner	Required evidence
C-30	Business/UI/safety regression	Product/module owners	Feature-off parity, human review and no autonomous workflow changes.
C-31	Disability accessibility and resilient user access	UX/product/QA	WCAG 2.2 AA workflow evidence, manual assistive-technology tests and safe slow-link/reconnect behavior.
C-32	Registered automation and delegated authority	Identity/backend/security	D1-D3; A-01/A-03; current user/client/task intersection and separate service roles.
C-33	Credential theft and ingress anti-bypass	Platform/identity	D2; A-02/A-04; origin, header, audience/proof and revocation enforcement.
C-34	Cumulative extraction and sensitive-flow misuse	Data/product/security	Approved cross-route limits/export rights; A-05/A-12 including legitimate-user regression.
C-35	Agent tool/output confinement	AI/platform/security	No model execution or automatic output fetch; A-06/A-07/A-11.
C-36	Local agent/tool-server isolation	Endpoint/release/security	Separate OS/workspace/network identity and reviewed capabilities; A-10/A-11.
C-37	Durable selective incident containment	Security/operations	Independent control path, restore/rollback persistence and controlled reopening; A-09.
C-38	Atomic provider/resource cost admission	Platform/finance/product	Pre-dispatch bounded reservations, uncertain-outcome reconciliation and concurrent A-08 evidence.

Before approval, also name support owners and approve business-user training on uncertainty, accessibility remediation and the provider/storage exit plan. Loss of a vendor must not make original project records or their authorized audit history unreadable.

Approval checklist:

- [ ] Scope, business impact and the no-ConPro-change restriction understood.
- [ ] B01-B08 resolved or explicitly blocked from production with owners.
- [ ] C-01 through C-38 have owners and linked implementation/test evidence.
- [ ] Classification, source visibility, processor and legal retention accepted.
- [ ] SLO, RPO/RTO, capacity envelope, costs and recovery evidence accepted.
- [ ] Backup isolation/restore and accessible end-to-end workflow evidence accepted.
- [ ] D1-D6 and A-01 through A-12 agent-defense evidence accepted before pilot enablement.
- [ ] Independent security/privacy review and residual-risk acceptance completed.
- [ ] Specific implementation batch, repository and UI scope explicitly authorized.

- [ ] Change authority, reviewer, date and rollback conditions recorded.

Until separately authorized, this remains a **documentation-only review package**. No ConPro changes, integration rollout, infrastructure installation, application implementation, commit or push is authorized by its creation.

23. Glossary

Term	Meaning in this design
Authoritative	The system/record entitled to decide a fact or permission, not merely a cached copy.
RAG	Retrieval-augmented generation: retrieve permitted evidence, then generate a bounded explanation.
mTLS	Mutual TLS: both service endpoints authenticate with certificates.
TTL	Time to live: an expiry interval, not a response-time limit or permission guarantee.
SLI/SLO	Measured service-level indicator / agreed target for that indicator.
RPO	Maximum accepted loss measured back from a disruption to the recovered data point.
RTO	Maximum accepted time to restore the defined, correct business service.
PITR/WAL	Point-in-time database recovery using compatible base backups and write-ahead logs.
WORM	Write once, read many: retention-enforced immutable storage, subject to the approved storage policy.
WCAG	Web Content Accessibility Guidelines; Level AA is the proposed accessibility target, not a current compliance claim.
Delegated agent	A registered automated client acting within the current intersection of user, client and task grants.
Sender-constrained token	A credential whose use requires proof of a bound key, not just possession of a bearer-token string.
DPoP	OAuth Demonstrating Proof of Possession; a standards-based sender-constraining option requiring reviewed implementation.
MCP	Model Context Protocol; a tool-connection interface, not proof that a tool or operator is trusted.
Containment	Durable scoped denial of affected operations, with independent administration and controlled reopening.
Outbox	Durable operation/event written in the same transaction as a business change.
Lease/fencing	Temporary worker ownership / checks that prevent an old worker from publishing after ownership changed.

Term	Meaning in this design
Tombstone	Durable withdrawal/deletion state that prevents stale data from being reintroduced.
RLS	Database row-level security; defense in depth, not the whole ConPro policy.
Fail closed	Withhold the protected operation when required authorization cannot be verified.
Hybrid retrieval	Independent lexical+dense branches under identical policy, not simply mirrored vector stores.
Derived data	Extracted text, embeddings, indexes, descriptions, answers and other transformations that can still disclose the source.

24. References

All references are consolidated here. Repository paths describe reviewed source or related documents, not approval to change them. `ConPro\` denotes the separate read-only ConPro repository; `app\` denotes the current RAG working tree. Line numbers are review-time locators and will change as code evolves. External references were consulted on 2026-10-16; use documentation compatible with the deployed version rather than blindly following a moving "current" URL.

24.1 Related project documents

1. **RAG operational baseline:** `docs\SECURITY_AND_RELIABILITY.md`. Current standalone authentication, ingestion, concurrency, retention and image processing behavior; not a claim that the ConPro connector exists.
2. **System-wide implementation review:** `docs\CONPRO_PMIS_RAG_IMPLEMENTATION_PLAN.md`. Source contracts, policy helper proposal, evidence/callback sequence, outbox, system-wide module roadmap and proposed reference fragments.
3. **Integration architecture review:** `docs\CONPRO_PMIS_RAG_INTEGRATION.md`. Historical design baseline; later operational hardening supersedes its older standalone-security assumptions.
4. **Hybrid implementation review:** `docs\RAG_HYBRID_IMPLEMENTATION_PLAN.md`. Independent lexical/dense retrieval, authorized subsets and fusion gates.

24.2 Reviewed application evidence

5. **ConPro topology and persistence:** `ConPro\docker-compose.yml:1-69`; `ConPro\backend\Dockerfile:1-29`. PostgreSQL 18 image/data mount, backend/frontend loopback bindings, scheduler and absence of declared backend media persistence in this configuration.
6. **ConPro database and media storage:** `ConPro\backend\config\settings.py:102-135`. PostgreSQL defaults/connection age, timezone and filesystem media backend.
7. **ConPro migration ownership:** `ConPro\backend\docker-entrypoint.sh:1-12`. Entry-point migrations/reporting installation before application start.
8. **ConPro scheduler behavior:** `ConPro\backend\apps\common\management\commands\run_scheduler.py:1-70`. Single looping management process and scheduled QC/ETL/audit-related tasks.
9. **ConPro authoritative project/record scope:** `ConPro\backend\apps\accounts\scoping.py:27-62,94-115`; `ConPro\backend\apps\documents\views.py:31-60`. Membership/role scope and additional document-visibility rules.

10. **Protected sharing and exact-version delivery:** `ConPro\backend\apps\documents\views.py:393-436`. Shared-link authorization is distinct from authenticated version download.
11. **ConPro audit ingress hints:** `ConPro\backend\apps\audit\middleware.py:12-42`. Request/source/forwarded header handling needs a trusted ingress boundary.
12. **Current RAG grant authority and fail-closed loading:** `app\auth.py:85-96,115-181`. Server-owned policy, authentication, project authorization and current-user rechecks.
13. **Privileged internal retrieval boundary:** `app\retrieval_service.py:66-97`. Service authentication does not itself establish individual ConPro source rights.
14. **Process-local queue:** `app\ingestion_jobs.py:18-101`. Bounded queue, volatile status, worker and safe error-code handling.
15. **Vector lifecycle and connection/snapshot limits:** `app\vector_store.py:289-315,385-464,541-586`. Local pgvector connection/revision, transactional replacement and local lock wrapper.
16. **Current storage/timeout/concurrency/image settings:** `app\config.py:87-138`. Explicit image enablement, process limits and optional retention configuration.
17. **Saved-answer payload lifecycle:** `app\answer_store.py:18-112`. Separate private storage, expiry, owner-qualified operations and scrubbing.
18. **Opt-in visual interpretation:** `app\image_description.py:25-93`. Normalized bounded image, pre-dispatch callback, model request and output checks.
19. **Metric limitations:** `app\slo_metrics.py:1-43,95-120`. In-process bounded collector, default SLO settings and retrieval heuristic.
20. **Current RAG deployment sketch:** `docker-compose.yml`. Private service split, API worker setting and persistent-backend assumptions; not a complete production control plane.

24.3 External engineering and security guidance

21. **OWASP, Retrieval-Augmented Generation Security Cheat Sheet.**
    https://cheatsheetseries.owasp.org/cheatsheets/RAG_Security_Cheat_Sheet.html
    Pipeline trust boundaries, provenance, index isolation, cache/deletion, observability and fail-closed controls. Guidance, not certification.
22. **PostgreSQL, Row Security Policies.** https://www.postgresql.org/docs/current/ddl-rowsecurity.html
    Default-deny policies and owner/superuser/`BYPASSRLS` behavior.
23. **PostgreSQL, Continuous Archiving and Point-in-Time Recovery.**
    https://www.postgresql.org/docs/current/continuous-archiving.html
    Base-backup/WAL requirements and restore limitations.
24. **Docker Official Image documentation, PostgreSQL, PGDATA.** https://github.com/docker-library/docs/blob/master/postgres/README.md#pgdata
    Raw documentation consulted: https://raw.githubusercontent.com/docker-library/docs/master/postgres/README.md
    PostgreSQL 18 version-specific data directory and changed volume root; verify the actual deployed image and migration procedure.
25. **NIST SP 800-34 Rev. 1, Contingency Planning Guide for Federal Information Systems.**
    https://csrc.nist.gov/pubs/sp/800/34/r1/upd1/final
    Business-impact-driven recovery planning and exercises; not a declaration that ConPro is compliant with a particular jurisdiction.
26. **Google SRE Workbook, Implementing SLOs.** https://sre.google/workbook/implementing-slos/
    User-centered indicators, objectives and error budgets; proposed numerical targets in this document still require owner approval and measurement.

27. **W3C, Web Content Accessibility Guidelines (WCAG) 2.2.** https://www.w3.org/TR/WCAG22/
    Normative success criteria and conformance requirements for the proposed Level AA target; automated checks alone do not establish conformance.
28. **W3C Web Accessibility Initiative, WCAG 2 Overview.** https://www.w3.org/WAI/standards-guidelines/wcag/
    Scope, accessibility principles, levels and supporting evaluation resources, including dynamic, mobile and AI web interfaces.
29. **CISA and partners, #StopRansomware Guide.** https://www.cisa.gov/stopransomware/ransomware-guide
    Offline encrypted backups, restore testing, cloud/immutable-storage considerations, least privilege and ransomware response. Backup schedules and the proposed 3-2-1-1-0 baseline still require local risk/owner approval.
30. **OWASP, Automated Threats to Web Applications.** https://owasp.org/www-project-automated-threats-to-web-applications/
    Redirected current page: https://owasp.org/projects/automated-threats-to-web-applications
    Taxonomy/context for unwanted automation and misuse of valid functionality; these requirements are independently written, not a reproduced OWASP handbook.
31. **OWASP API Security Top 10, 2023.** https://owasp.org/API-Security/editions/2023/en/0x11-t10/
    Redirected current page: https://api-security.owasp.org/editions/2023/en/0x11-t10/
    Object/property/function authorization, authentication, resource consumption, sensitive business flows, SSRF and API exposure risks.
32. **NIST SP 800-207, Zero Trust Architecture.** https://csrc.nist.gov/pubs/sp/800/207/final
    Resource-focused authorization and no implicit trust from network location; a design reference, not a claim of NIST compliance or a purchased product.
33. **IETF RFC 9700, Best Current Practice for OAuth 2.0 Security.** https://www.rfc-editor.org/rfc/rfc9700.html
    OAuth security, audience restrictions, replay/token-theft defenses and sender-constrained token options. Use reviewed protocol libraries rather than implementing proof validation from these design fragments.